

(b) Guía metodológica detallada para la Encuesta CVSS 4.0 y Gestión de Vulnerabilidades

1. Objetivo general de la encuesta

La encuesta tiene como objetivo medir el grado de adopción y uso avanzado de CVSS (especialmente CVSS 4.0) y de las prácticas de gestión de vulnerabilidades en organizaciones españolas, en el marco de las obligaciones y tendencias marcadas por NIS2 y el Cyber Resilience Act (CRA).[web:16][web:17][web:56][web:57]

Se busca obtener información comparable y accionable que permita:

- Construir indicadores de gestión de vulnerabilidades (IGM) a nivel nacional.[web:63]
- Identificar brechas de madurez frente a las mejores prácticas recogidas en CVSS v4.0 (Base, Threat, Environmental, Supplemental).[web:16][web:55][web:58]
- Evaluar hasta qué punto las organizaciones están alineando su gestión de vulnerabilidades con los requisitos normativos europeos (NIS2, CRA, otros).[web:56][web:57][web:61]

2. Población objetivo y muestra

- Población objetivo: organizaciones con presencia significativa en España (empresas privadas, entidades públicas, organizaciones del tercer sector) con un mínimo de capacidad TIC propia o externalizada.
- Respondentes objetivo: CISO, CIO, CTO, responsables de seguridad, riesgo, continuidad o cumplimiento con visión transversal sobre la gestión de vulnerabilidades.

Se recomienda:

- Asegurar representación de sectores regulados (energía, transporte, salud, finanzas, administración pública) sujetos a NIS2.[web:56][web:61][web:64]
- Incluir tanto grandes organizaciones como pymes, para captar diferencias de capacidad y enfoque.

3. Estructura de la encuesta

La encuesta se estructura en 12 bloques:

1. Información general de la organización.
2. Madurez general en gestión de vulnerabilidades.
3. Uso de CVSS.
4. Adopción de CVSS 4.0 y métricas Base.
5. Métricas Threat y explotación real.
6. Métricas Environmental y criticidad local.
7. Métricas Supplemental.
8. Integración con marcos normativos.
9. Indicadores de gestión (IGM).
10. ROI y percepción de valor.

11. Perspectiva estratégica y de futuro.

12. Comentarios cualitativos.

4. Tipo de preguntas y escalas de respuesta

Se utilizan principalmente:

- Preguntas de selección única: adecuadas para clasificar el nivel de adopción o la existencia de prácticas.
- Preguntas de selección múltiple: para capturar variedad de prácticas y fuentes de información.
- Escalas tipo Likert (1–5) o gradientes de madurez, que facilitan construcción de índices y comparación inter-organizacional.
- Preguntas abiertas controladas, para recoger matices cualitativos.

5. Construcción de índices de madurez (IGM)

Se recomienda definir uno o varios **Índices Globales de Madurez (IGM)** a partir de las respuestas, por ejemplo:

5.1. IGM-CVSS (Índice de madurez en uso de CVSS)

Componentes sugeridos:

- Uso sistemático de CVSS (pregunta 3.1).
- Versión/es utilizada/s (3.2) con mayor peso para adopción de CVSS 4.0.[web:16][web:55]
- Revisión y recalculado de métricas Base (4.3, 4.4).[web:17][web:63]
- Uso de métricas Threat y Environmental (5.1, 6.1).[web:16][web:17]
- Conocimiento y utilización de métricas Supplemental (7.1–7.5).[web:55][web:58]

Cada ítem puede normalizarse a una escala 0–1 y promediarse ponderando según relevancia.

5.2. IGM-GV (Índice de madurez en gestión de vulnerabilidades)

Componentes sugeridos:

- Existencia de proceso formal de gestión de vulnerabilidades (2.1).[web:63]
- Frecuencia de identificación de vulnerabilidades (2.2).
- Uso de múltiples fuentes (2.3).
- Uso de indicadores cuantitativos y KPIs (9.1, 9.2).[web:61]
- Periodicidad del reporte a la dirección (9.3).[web:61]

5.3. IGM-Norm (Índice de alineamiento normativo)

Componentes sugeridos:

- Sujeción a NIS2 y/o CRA (8.1, 8.3).[web:56][web:57][web:62]
- Uso de CVSS para demostrar cumplimiento (8.2).
- Existencia de procesos de vulnerability handling y coordinated vulnerability disclosure (8.4).[web:56][web:57]

5.4. Construcción práctica

La plantilla Excel propuesta en el documento (e) permitirá:

- Asignar puntuaciones numéricas a cada opción.
- Calcular automáticamente los índices por organización.
- Generar estadísticas descriptivas (media, mediana, cuartiles) y segmentaciones.

6. Validez y confiabilidad

- Piloto: se recomienda realizar un piloto con 5–10 organizaciones de diferentes sectores, para validar la claridad de las preguntas y la relevancia de las escalas.
- Fiabilidad interna: para índices como IGM-CVSS o IGM-GV, evaluar la consistencia interna (por ejemplo, alfa de Cronbach) si el tamaño de la muestra lo permite.
- Comparabilidad internacional: las preguntas están alineadas con la estructura de CVSS v4.0 y con requerimientos europeos, lo que facilita comparaciones con estudios similares en otros países.
[web:16][web:17][web:56][web:57]

7. Consideraciones éticas y de confidencialidad

- Garantizar anonimato o seudonimización de respuestas.
- Comunicar claramente el propósito: mejora de la resiliencia y madurez, no “caza de brujas” regulatoria.
- Asegurar que los datos se almacenan y procesan conforme a la normativa aplicable (RGPD, etc.).

8. Uso de los resultados

Los resultados podrán utilizarse para:

- Elaborar informes sectoriales y comparativos de madurez.
- Identificar necesidades de formación y apoyo (por ejemplo, en CVSS 4.0 o NIS2).[web:58][web:63]
- Fundamentar propuestas de políticas públicas o guías nacionales sobre gestión de vulnerabilidades.
- Medir evolución temporal si la encuesta se repite (por ejemplo, anual).

La narrativa explicativa (documento (c)) y el reporte ejecutivo (documento (f)) ofrecen plantillas para comunicar los resultados a diferentes audiencias.